

UNIVERSITÀ DEGLI STUDI DI SALERNO

Corso di Laurea in Informatica

Corso di Ingegneria del Software

Anno Accademico 2024/2025

Tech4All

Test Document

Piattaforma web per l'alfabetizzazione digitale

GRUPPO C06

Project manager

Ferdinando Boccia

Domenico D'Antuono

Team member

Marco Capuano

Giovanni Cerchia

Arcangelo Ciaramella

Silvana De Martino

Giovanni Esposito

Luigi Nasta

Giovanni Salsano

Giuseppe Staiano

Documento	TD
-----------	----

Versione	1.0
----------	-----

Indice

1	Introduzione	1
1.1	Scopo del documento	1
1.2	Relazione con gli altri documenti	1
1.3	Riferimenti	2
2	Strategia di verifica	3
2.1	Livelli di verifica	3
2.2	Approccio	3
2.3	Criteri di ingresso e di uscita	4
2.4	Sospensione e ripresa	4
2.5	Ambiente e strumenti	4
2.5.1	Isolamento dal database	5
2.6	Funzionalità da verificare	5
2.7	Funzionalità non verificate automaticamente	6
3	Derivazione dei casi di test	7
3.1	Il metodo della category partition	7
3.2	Convenzioni di identificazione	8
3.3	Esempio completo: inserimento di un feedback	8
3.3.1	Passo 1 — Parametri e condizioni dell’ambiente	8
3.3.2	Passo 2 e 3 — Categorie e scelte	8
3.3.3	Passo 4 — Vincoli e test frame	9
3.3.4	Dal test frame al codice	10
4	Specifica dei casi di test	11
4.1	Autenticazione	11
4.1.1	Categorie	11
4.1.2	Casi di test	11
4.2	Gestione account	12
4.3	Gestione tutorial	13
4.3.1	Categorie	13
4.3.2	Casi di test	14
4.4	Gestione quiz	15
4.4.1	Categorie	15
4.4.2	Casi di test — definizione del quiz	15
4.4.3	Casi di test — svolgimento e correzione	16

4.5	Gestione obiettivi	17
4.6	Controllo degli accessi	18
4.7	Infrastruttura	19
4.8	Casi di test di sistema	20
5	Esecuzione e risultati	22
5.1	Esito complessivo	22
5.2	Difetti individuati e risolti	23
5.2.1	Difetti di sicurezza	23
5.2.2	Difetti funzionali	24
5.2.3	Difetti individuati dalle prove di sistema	25
5.3	Copertura del codice	26
5.3.1	Perimetro di misurazione	26
5.3.2	Risultati	26
5.3.3	Analisi delle parti scoperte	27
6	Conclusioni	28
6.1	Valutazione complessiva	28
6.2	Limiti della verifica	28
6.3	Interventi proposti	29
7	Glossario	30
7.1	Termini del dominio	30
7.2	Termini tecnici	31
7.3	Acronimi	32
A	Matrice di tracciabilità	33
A.1	Requisiti funzionali	33
A.2	Requisiti non funzionali	34
	Riferimenti bibliografici	37

Introduzione

1.1 Scopo del documento

Questo documento descrive come Tech4All è verificato: la strategia adottata, il metodo con cui i casi di test sono stati derivati, la loro specifica, i risultati dell'esecuzione e i limiti della verifica.

Rispetto alla struttura suggerita da IEEE 829 [1], il documento riunisce in un solo testo ciò che lo standard distribuisce fra piano di test, specifica dei casi, rapporto sugli incidenti e rapporto riassuntivo. La ragione è pratica: quei quattro documenti condividono premesse, glossario e strumenti, e mantenerli separati per un sistema di questa scala produce ripetizione senza aggiungere rigore.

La riunione dei quattro documenti ha però una conseguenza sull'ordine di lettura: il documento è redatto man mano che la verifica procede, e i capitoli che descrivono strategia e casi di test precedono l'esecuzione anche cronologicamente. Il capitolo 5 riporta l'esito dell'ultima esecuzione della suite e i difetti individuati fino a quel momento.

1.2 Relazione con gli altri documenti

Il documento chiude la catena di tracciabilità del progetto.

Dal RAD

provengono i requisiti funzionali e non funzionali, che sono l'oggetto della verifica, e i criteri di accettazione, che ne sono l'oracolo. Un requisito non funzionale del RAD è formulato in modo da poter diventare un'asserzione: è la ragione per cui, in quel documento, ogni requisito ha un criterio osservabile.

Dal SDD

provengono i confini delle unità da verificare: servizi, middleware e serializzazione. La scelta di iniettare le dipendenze dai costruttori, motivata in quel documento, è ciò che rende la verifica in isolamento possibile senza artifici.

Verso entrambi

questo documento riporta, in sezione 6.2, ciò che la verifica *non* copre: sono i punti in cui i compromessi dichiarati nel SDD si traducono in rischio residuo.

La matrice che lega ogni requisito ai casi di test che lo verificano è nell'appendice A.

1.3 Riferimenti

Il metodo di derivazione dei casi di test è quello della *category partition* di Ostrand e Balcer [2]. La terminologia relativa alla documentazione della verifica segue IEEE 829 [1]. Le classi di vulnerabilità citate nei casi di test di sicurezza fanno riferimento alla classificazione OWASP [3].

Strategia di verifica

2.1 Livelli di verifica

La verifica è organizzata su tre livelli, con obiettivi distinti e costi crescenti.

Livello	Che cosa verifica	Come
Unità	Le regole di dominio dei servizi e le funzioni di infrastruttura prese singolarmente.	Il servizio è costruito con DAO simulati passati al costruttore. Nessuna rete, nessun database.
Integrazione	La composizione fra rotte, middleware e serializzazioni: controllo degli accessi, validazione, forma delle risposte, traduzione degli errori.	L'applicazione Express è costruita con servizi simulati e interrogata via HTTP con supertest, senza occupare una porta.
Sistema	Il funzionamento end-to-end su un'istanza reale, database compreso.	Prove manuali documentate in sezione 4.8, eseguite su una base di dati creata dagli script del progetto.

Il livello di unità e quello di integrazione sono automatici ed eseguiti a ogni modifica del codice. Il livello di sistema è manuale: è l'unico che esercita le interrogazioni SQL reali, ed è quindi la contromisura al compromesso dichiarato nel SDD sulla sostituzione del livello di persistenza.

2.2 Approccio

L'approccio è *white-box*: i casi di test sono derivati conoscendo la struttura interna del codice, e la loro adeguatezza è misurata sulla copertura raggiunta. La scelta è motivata dal fatto che gli oracoli più importanti del sistema — la soglia di superamento di un quiz, l'esclusione delle soluzioni dalla serializzazione, la propagazione della connessione transazionale — non sono osservabili dall'esterno senza conoscere il progetto.

I casi di test non sono però scritti guardando l'implementazione riga per riga: sono derivati dalle specifiche con il metodo della category partition (capitolo 3), e la conoscenza della struttura interna serve a verificare che nessun percorso sia rimasto scoperto. Un test scritto per inseguire una riga di codice verifica che il codice faccia ciò che fa, non ciò che deve fare.

2.3 Criteri di ingresso e di uscita

Criterio	Condizione
Ingresso	Il codice compila senza errori di tipo e supera l'analisi statica. Una funzionalità non entra in verifica finché la sua specifica non è formulata come requisito con criterio di accettazione.
Uscita	Tutti i casi di test superati; copertura non inferiore all'85% delle istruzioni e all'80% delle diramazioni; nessun difetto aperto di gravità alta o critica.

Le soglie di copertura non sono un valore riportato a posteriori: sono configurate nella suite, che fallisce se non vengono raggiunte. La differenza è sostanziale — una soglia dichiarata in un documento è un auspicio, una soglia imposta dalla suite è un vincolo.

2.4 Sospensione e ripresa

L'esecuzione della verifica è sospesa quando il sistema non soddisfa più i criteri d'ingresso: un errore di compilazione, un fallimento dell'analisi statica o un difetto che impedisce l'esecuzione della suite. In questi casi proseguire non produrrebbe informazione, perché i fallimenti successivi sarebbero conseguenza del primo.

La verifica riprende quando la causa è rimossa e la suite viene rieseguita per intero. Non si riprende dall'ultimo test fallito: un difetto corretto può averne introdotto un altro altrove, e solo un'esecuzione completa lo rivelerebbe.

2.5 Ambiente e strumenti

Strumento	Ruolo
Jest	Esecutore dei test, gestione dei doppi e misurazione della copertura.
ts-jest	Compilazione TypeScript durante l'esecuzione: i test sono scritti nello stesso linguaggio del codice e ne condividono i tipi.

Strumento	Ruolo
supertest	Invio di richieste HTTP all'applicazione Express in memoria, senza aprire una porta di rete.
TypeScript	Controllo dei tipi in modalità stretta, primo livello di verifica: molte classi di errore non arrivano mai a essere eseguite.
ESLint e Prettier	Analisi statica e uniformità formale del codice.
GitHub Actions	Esecuzione automatica di analisi statica, controllo dei tipi, test e compilazione a ogni integrazione.

2.5.1 Isolamento dal database

Il modulo che espone il pool di connessioni è sostituito globalmente da un doppio all'avvio della suite. Nessun test apre una connessione: l'intera verifica automatica gira su qualunque macchina senza MySQL installato e senza variabili d'ambiente reali.

La scelta ha due conseguenze da tenere presenti. La prima è positiva: la suite completa impiega pochi secondi, quindi viene eseguita spesso. La seconda è il limite già dichiarato: le interrogazioni SQL non sono verificate automaticamente (sezione 6.2).

2.6 Funzionalità da verificare

Area	Oggetto della verifica
Autenticazione	Politica delle password, hashing, riconoscimento delle credenziali, indistinguibilità fra email inesistente e password errata, apertura e chiusura della sessione.
Gestione account	Aggiornamento parziale del profilo, unicità dell'email, cambio password con verifica di quella attuale, cancellazione.
Gestione tutorial	Vincoli di dominio su titolo, testo, categoria e immagine; sanificazione del contenuto; filtro e ricerca; ciclo di vita del tutorial.
Gestione quiz	Vincoli sulle domande; correzione e soglia di superamento; associazione delle risposte per identificativo; conservazione di un esito positivo; esclusione delle soluzioni dalla rappresentazione.
Gestione feedback	Vincoli su valutazione e commento; unicità per coppia utente-tutorial; distinzione fra proprietà del dato e potere di moderazione.

Area	Oggetto della verifica
Gestione obiettivi	Assegnazione automatica alle soglie; idempotenza; abbinamento fra conseguimenti e obiettivi.
Controllo degli accessi	Matrice completa: per ogni rotta protetta, comportamento verso anonimo, utente e amministratore.
Infrastruttura	Gerarchia degli errori, traduzione in risposte HTTP, gestione dei nomi di file, composizione dell'applicazione.

2.7 Funzionalità non verificate automaticamente

Esclusione	Motivazione
Interrogazioni SQL e vincoli del database	Il livello di persistenza è sostituito da doppi. Coperti dalle prove di sistema (sezione 4.8).
Trigger di ricalcolo della valutazione media	Vivono nel database. Coperti dalle prove di sistema.
Interfaccia utente	Non esistono test automatici sul client. Il comportamento è verificato manualmente; il controllo dei tipi e l'analisi statica coprono la parte strutturale.
Elaborazione delle immagini	Il ridimensionamento è delegato a una libreria esterna e non è riverificato. La logica applicativa che la circonda — generazione del nome, validazione del percorso — è invece coperta.
Widget conversazionale	Componente esterno, fuori dal perimetro del sistema.

Derivazione dei casi di test

Le tabelle di parametri e i *test frame* che compaiono nel capitolo successivo non sono elenchi arbitrari: sono il prodotto di un metodo. Questo capitolo lo descrive e ne mostra l'applicazione completa a un caso, così che le tabelle che seguono siano leggibili come risultato e non come premessa.

3.1 Il metodo della category partition

Il metodo di Ostrand e Balcer [2] deriva i casi di test dalla specifica di una funzione attraverso quattro passi.

1. **Individuare i parametri e le condizioni dell'ambiente** che influenzano il comportamento della funzione. I parametri sono gli argomenti; le condizioni dell'ambiente sono lo stato del sistema al momento della chiamata.
2. **Individuare le categorie:** per ciascun parametro, le proprietà che ne determinano il trattamento. Per una stringa, tipicamente la lunghezza e il formato; per un riferimento, l'esistenza dell'oggetto riferito.
3. **Partizionare ogni categoria in scelte**, cioè in classi di valori trattati allo stesso modo. Ogni scelta è annotata come valida ([valido]) o non valida ([errore]).
4. **Comporre i test frame** combinando una scelta per categoria, applicando i vincoli che escludono le combinazioni impossibili o ridondanti.

Senza il quarto passo il numero di combinazioni esplode: con sei categorie da tre scelte si avrebbero 729 casi. I vincoli lo riducono a un numero gestibile, e sono di due tipi.

[error]

Una scelta non valida produce un solo test frame, in cui tutti gli altri parametri assumono un valore valido. Non ha senso combinare due errori: la funzione si arresta al primo, e il secondo non verrebbe mai raggiunto.

[property] e [if]

Una scelta può essere selezionata solo se un'altra è stata selezionata. Serve a escludere combinazioni impossibili: non si può verificare il formato di un'email se l'email è assente.

3.2 Convenzioni di identificazione

Elemento	Convenzione
Scelta	Sigla del parametro seguita da un numero progressivo. Esempio: LC1 è la prima scelta della categoria «lunghezza del commento».
Test frame	Insieme delle scelte selezionate. Esempio: {LC2, VA2, EF1, TU1}.
Caso di test	TC_<area>_<numero>, dove <area> è la sigla del sottosistema usata nel RAD. Esempio: TC_FB_03.

3.3 Esempio completo: inserimento di un feedback

Si applica il metodo all'operazione `creaFeedback(utenteId, tutorialId, dati)` del sottosistema Gestione feedback, che realizza RF_FB_3.

3.3.1 Passo 1 — Parametri e condizioni dell'ambiente

Elemento	Tipo	Descrizione
valutazione	parametro	Voto numerico assegnato al tutorial.
commento	parametro	Testo del giudizio.
tutorialId	parametro	Tutorial oggetto della valutazione.
utenteId	parametro	Autore, ricavato dalla sessione.
Feedback preesistente	ambiente	Presenza di un feedback della stessa coppia utente-tutorial.

L'ultima riga è una condizione dell'ambiente e non un parametro: non è passata alla funzione ma ne determina il comportamento, ed è la ragione per cui il metodo distingue i due concetti.

3.3.2 Passo 2 e 3 — Categorie e scelte

Parametro	Categoria	Scelta	Sigla
valutazione	Intervallo	< 1	[errore] VA1
		$1 \leq v \leq 5$	[valido] VA2
		> 5	[errore] VA3

Parametro	Categoria	Scelta	Sigla
	Tipo	non intero	[errore] VA4
commento	Lunghezza	< 2 caratteri	[errore] LC1
		da 2 a 500 caratteri	[valido] LC2
		> 500 caratteri	[errore] LC3
tutorialId	Esistenza	tutorial inesistente	[errore] TU1
		tutorial esistente	[valido] TU2
Ambiente	Feedback preesistente	presente	[errore] FP1
		assente	[valido] FP2

3.3.3 Passo 4 — Vincoli e test frame

I vincoli applicati sono due, entrambi del tipo [error]:

- una scelta non valida di valutazione o commento rende irrilevanti le scelte successive, perché la validazione dei dati precede ogni accesso al database;
- la verifica dell'esistenza del tutorial precede quella del feedback preesistente, quindi TU1 rende irrilevante la scelta su FP.

Le combinazioni passano così da $4 \times 3 \times 2 \times 2 = 48$ a otto test frame.

Caso	Test frame	Esito atteso	Oracolo
TC_FB_01	{VA2, LC2, TU2, FP2}	Feedback registrato	L'oggetto restituito riporta autore, tutorial, voto e commento; il DAO di creazione è stato invocato.
TC_FB_02	{VA1, LC2, TU2, FP2}	ValidationError	Nessuna scrittura sul database.
TC_FB_03	{VA3, LC2, TU2, FP2}	ValidationError	Come sopra.

Caso	Test frame	Esito atteso	Oracolo
TC_FB_04	{VA4, LC2, TU2, FP2}	ValidationError	Come sopra: una valutazione non intera è rifiutata anche se compresa nell'intervallo.
TC_FB_05	{VA2, LC1, TU2, FP2}	ValidationError	Come sopra.
TC_FB_06	{VA2, LC3, TU2, FP2}	ValidationError	Come sopra.
TC_FB_07	{VA2, LC2, TU1}	NotFoundError	L'esistenza del tutorial è verificata prima dell'unicità del feedback.
TC_FB_08	{VA2, LC2, TU2, FP1}	ConflictError	Il feedback preesistente non viene sovrascritto.

Un caso che il metodo non produce. La specifica prevede che l'autore del feedback sia sempre l'utente indicato dal chiamante, mai un valore proveniente dalla richiesta. Non è una partizione di un parametro: è una proprietà della funzione. Le proprietà di questo tipo — che il RAD elenca come requisiti non funzionali — richiedono casi di test scritti a parte, e sono raccolte in sezione 4.6.

3.3.4 Dal test frame al codice

Ogni test frame corrisponde a una asserzione eseguibile. Il caso TC_FB_08 è realizzato così:

```

1 it("impedisce due feedback dello stesso utente sullo stesso tutorial",
2   async () => {
3     feedbackDao.find.mockResolvedValue(unFeedback()); // FP1
4
5     await expect(
6       servizio.creaFeedback(1, 1, datiValidi), // VA2, LC2, TU2
7     ).rejects.toBeInstanceOf(ConflictError);
8   });

```

Listing 3.1. Realizzazione di TC_FB_08.

Il doppio del DAO realizza la condizione dell'ambiente; gli argomenti realizzano le scelte sui parametri; l'asserzione è l'oracolo.

Specifica dei casi di test

I casi di test sono raggruppati per area funzionale. Per ciascuna area sono riportate le categorie individuate e i casi che ne derivano, con l'oracolo che stabilisce l'esito atteso. I casi dell'area Feedback sono già stati derivati per esteso in sezione 3.3 e non sono ripetuti.

4.1 Autenticazione

4.1.1 Categorie

Parametro	Categoria	Scelte
email	Formato	non conforme [errore]; conforme [valido]
	Esistenza	già registrata [errore]; libera [valido]
password	Politica	priva di maiuscola, cifra o carattere speciale, oppure più corta di otto caratteri [errore]; conforme [valido]
	Corrispondenza	diversa da quella memorizzata [errore]; corrispondente [valido]
nome, cognome	Lunghezza	fuori dall'intervallo 2–50 [errore]; nell'intervallo [valido]
	Formato	contiene cifre o simboli [errore]; solo lettere, apostrofi e trattini [valido]

4.1.2 Casi di test

Caso	Condizione	Oracolo
TC_AU_01	Registrazione con dati conformi	L'utente è creato con ruolo <i>utente</i> .
TC_AU_02	Registrazione con password non conforme	ValidationError; nessun utente creato.
TC_AU_03	Registrazione con email già registrata	ConflictError; nessun utente creato.
TC_AU_04	Registrazione con dati conformi	Il valore memorizzato non coincide con la password, inizia con il prefisso di uno hash bcrypt e la verifica dell'hash sulla password originale ha successo.
TC_AU_05	Accesso con credenziali corrette	Restituito l'utente corrispondente.
TC_AU_06	Accesso con password errata	UnauthorizedError.
TC_AU_07	Accesso con email inesistente e accesso con password errata	I due messaggi d'errore coincidono. Verifica RNF_F_1 sotto il profilo dell'enumerazione degli account.
TC_AU_08	Interrogazione su email registrata	Segnalata come non disponibile.
TC_AU_09	Interrogazione su email libera	Segnalata come disponibile.
TC_AU_10	Accesso riuscito, livello HTTP	La risposta reca un cookie con gli attributi HttpOnly e SameSite=Lax.
TC_AU_11	Accesso riuscito, livello HTTP	Il corpo della risposta contiene esattamente i campi previsti dal DTO e non contiene la password né il suo hash. Verifica RNF_F_1.
TC_AU_12	Registrazione riuscita, livello HTTP	Nessun cookie di sessione: la registrazione non autentica.
TC_AU_13	Chiusura della sessione	La risposta invalida il cookie.
TC_AU_14	Errore imprevisto durante l'accesso	La risposta è 500 e non contiene il messaggio dell'eccezione originale. Verifica RNF_A_2.

4.2 Gestione account

Caso	Condizione	Oracolo
TC_AC_01	Aggiornamento di nome e cognome	I due campi sono modificati e persistiti.

Caso	Condizione	Oracolo
TC_AC_02	Aggiornamento del solo nome	Il cognome resta invariato: l'aggiornamento è parziale.
TC_AC_03	Aggiornamento con email di un altro account	ConflictError; nessuna scrittura.
TC_AC_04	Aggiornamento con la propria email invariata	Nessun controllo di unicità viene eseguito.
TC_AC_05	Cambio password senza indicare quella attuale	ValidationError.
TC_AC_06	Cambio password con password attuale errata	UnauthorizedError.
TC_AC_07	Cambio password con nuova password non conforme	ValidationError.
TC_AC_08	Cambio password valido	Il nuovo hash verifica la nuova password.
TC_AC_09	Cancellazione di un account esistente	Operazione conclusa senza errore.
TC_AC_10	Cancellazione di un account inesistente	NotFoundError.

4.3 Gestione tutorial

4.3.1 Categorie

Parametro	Categoria	Scelte
titolo	Lunghezza	< 5 [errore]; 5–100 [valido]; > 100 [errore]
testo	Lunghezza	< 20 [errore]; 20–65535 [valido]
	Contenuto	con costrutti eseguibili; solo marcatori di formattazione
categoria	Appartenenza	non fra quelle ammesse [errore]; ammessa [valido]
grafica	Estensione	diversa da png, jpg, jpeg, webp [errore]; ammessa [valido]

4.3.2 Casi di test

Caso	Condizione	Oracolo
TC_CT_01	Creazione con dati conformi	Il tutorial è persistito.
TC_CT_02	Titolo più corto del minimo	ValidationError.
TC_CT_03	Titolo più lungo del massimo	ValidationError.
TC_CT_04	Testo più corto del minimo	ValidationError.
TC_CT_05	Categoria non ammessa	ValidationError.
TC_CT_06	Immagine con estensione non ammessa	ValidationError.
TC_CT_07	Contenuto con marcatore script	Il testo memorizzato non contiene il marcatore, ma conserva la parte legittima. Verifica RNF_F_5.
TC_CT_08	Contenuto con attributo di evento	L'attributo non compare nel testo memorizzato. Verifica RNF_F_5.
TC_CT_09	Catalogo senza filtro	Restituito l'intero catalogo; nessun filtro applicato.
TC_CT_10	Filtro con stringa vuota	Trattato come assenza di filtro.
TC_CT_11	Filtro con categoria ammessa	La restrizione è passata al livello di persistenza, non applicata in memoria. Verifica RNF_P_2.
TC_CT_12	Filtro con categoria inesistente	ValidationError.
TC_CT_13	Ricerca con chiave composta da soli spazi	Elenco vuoto senza interrogare il database.
TC_CT_14	Ricerca con chiave circondata da spazi	La chiave è ripulita prima dell'interrogazione.
TC_CT_15	Aggiornamento di un tutorial esistente	I campi sono modificati e persistiti.
TC_CT_16	Aggiornamento di un tutorial inesistente	NotFoundError.
TC_CT_17	Ritiro di un tutorial esistente	Operazione conclusa.
TC_CT_18	Ritiro di un tutorial inesistente	NotFoundError.
TC_CT_19	Creazione senza immagine di copertina, livello HTTP	400; il servizio non è invocato.
TC_CT_20	Aggiornamento con nuova copertina, livello HTTP	Il servizio riceve il percorso della copertina normalizzata.

Caso	Condizione	Oracolo
TC_CT_21	Aggiornamento senza copertina, livello HTTP	Il servizio riceve la copertina già presente: l'immagine non viene persa.

4.4 Gestione quiz

4.4.1 Categorie

Parametro	Categoria	Scelte
domande	Cardinalità	nessuna [errore]; almeno una [valido]
domanda.testo	Lunghezza	< 2 [errore]; 2–255 [valido]; > 255 [errore]
risposte	Cardinalità	< 2 [errore]; 2–5 [valido]
	Risposte corrette	nessuna [errore]; esattamente una [valido]; più di una [errore]
risposteFornite	Copertura	nessuna; parziale; completa
	Riferimenti	a domande del quiz; a domande estranee
	Ordine	uguale a quello delle domande; invertito
Ambiente	Svolgimento precedente	assente; presente non superato; presente superato

4.4.2 Casi di test — definizione del quiz

Caso	Condizione	Oracolo
TC_QZ_01	Quiz con una domanda conforme	Il quiz è persistito.
TC_QZ_02	Tutorial inesistente	NotFoundError.
TC_QZ_03	Tutorial con quiz già presente	ConflictError.
TC_QZ_04	Elenco di domande vuoto	ValidationError.
TC_QZ_05	Domanda più corta del minimo	ValidationError.

Caso	Condizione	Oracolo
TC_QZ_06	Domanda più lunga del massimo	ValidationError.
TC_QZ_07	Risposta più corta del minimo	ValidationError.
TC_QZ_08	Domanda con una sola opzione	ValidationError.
TC_QZ_09	Domanda senza risposte corrette	ValidationError.
TC_QZ_10	Domanda con due risposte corrette	ValidationError.
TC_QZ_11	Ridefinizione di un quiz esistente	Le domande precedenti sono sostituite.
TC_QZ_12	Ridefinizione di un quiz inesistente	NotFoundError.
TC_QZ_13	Rimozione di un quiz esistente	Operazione conclusa.
TC_QZ_14	Rimozione di un quiz inesistente	NotFoundError.

4.4.3 Casi di test — svolgimento e correzione

Caso	Condizione	Oracolo
TC_QZ_15	Cinque risposte corrette su cinque	Esito positivo; cinque risposte esatte.
TC_QZ_16	Tre risposte corrette su cinque	Esito negativo: $3/5 = 0,60 < 0,70$.
TC_QZ_17	Sette risposte corrette su dieci	Esito positivo: $7/10 = 0,70$, esattamente il valore di soglia. Caso di frontiera.
TC_QZ_18	Risposte corrette inviate in ordine invertito	Esito positivo: l'associazione avviene per identificativo e non per posizione.
TC_QZ_19	Risposta riferita a una domanda di un altro quiz	Ignorata; nessuna risposta conteggiata come esatta.
TC_QZ_20	Consegna senza alcuna risposta	Esito negativo, ma le soluzioni di tutte le domande sono restituite.
TC_QZ_21	Consegna su quiz già superato, con esito peggiore	Lo svolgimento non viene sovrascritto. Verifica RNF_A_4.
TC_QZ_22	Consegna su quiz non superato in precedenza	Il nuovo svolgimento è registrato.

Caso	Condizione	Oracolo
TC_QZ_23	Consegna che porta a tre quiz superati	Il contatore dell'utente è aggiornato al valore conteggiato dagli svolgimenti, non incrementato. Verifica RNF_A_4.
TC_QZ_24	Consegna che non modifica il numero di quiz superati	Nessuna scrittura sul contatore.
TC_QZ_25	Consegna che raggiunge la soglia di un obiettivo	L'obiettivo sbloccato è riportato nell'esito.
TC_QZ_26	Quiz inesistente	NotFoundError.
TC_QZ_27	Utente inesistente	NotFoundError.
TC_QZ_28	Quiz privo di domande	ValidationError.
TC_QZ_29	Lettura del quiz, livello HTTP	La rappresentazione non contiene alcun campo che distingua la risposta corretta, e ogni risposta espone solo identificativo e testo. Verifica RNF_F_6.
TC_QZ_30	Consegna con risposte prive di identificativi, livello HTTP	400; il servizio non è invocato.

4.5 Gestione obiettivi

Caso	Condizione	Oracolo
TC_OB_01	Zero quiz superati, soglia minima uno	Nessun obiettivo assegnato.
TC_OB_02	Tre quiz superati, soglie 1, 3 e 5	Assegnati i due obiettivi con soglia 1 e 3, non il terzo.
TC_OB_03	Tre quiz superati, obiettivo con soglia 1 già conseguito	Assegnato solo l'obiettivo con soglia 3.
TC_OB_04	Nessun nuovo traguardo raggiunto	Nessuna assegnazione: l'operazione è idempotente.
TC_OB_05	Assegnazione dentro una transazione	La connessione transazionale è propagata al livello di persistenza.
TC_OB_06	Utente con un conseguimento	Il badge restituito è abbinato al proprio obiettivo.
TC_OB_07	Conseguimento il cui obiettivo è stato eliminato	Il conseguimento è omesso, senza errore.

Caso	Condizione	Oracolo
TC_OB_08	Creazione con dati conformi	L'obiettivo è persistito.
TC_OB_09	Creazione con nome già usato	ConflictError.
TC_OB_10	Nome più corto del minimo	ValidationError.
TC_OB_11	Descrizione più corta del minimo	ValidationError.
TC_OB_12	Soglia pari a zero	ValidationError.
TC_OB_13	Soglia non intera	ValidationError.
TC_OB_14	Badge assente	ValidationError.
TC_OB_15	Aggiornamento di un obiettivo esistente	I campi sono modificati.
TC_OB_16	Aggiornamento di un obiettivo inesistente	NotFoundError.
TC_OB_17	Eliminazione di un obiettivo esistente	Operazione conclusa.
TC_OB_18	Eliminazione di un obiettivo inesistente	NotFoundError.

4.6 Controllo degli accessi

Questa sezione verifica la matrice di controllo degli accessi del SDD. Il criterio di adeguatezza non è la copertura del codice ma la copertura della matrice: per ogni rotta protetta esiste un caso per ciascun livello di autorizzazione previsto.

Caso	Condizione	Oracolo
TC_AX_01	Ognuna delle sette rotte riservate agli amministratori, chiamante anonimo	401. Verifica RNF_F_2.
TC_AX_02	Le stesse rotte, chiamante autenticato non amministratore	403. Verifica RNF_F_3.
TC_AX_03	Le stesse rotte, chiamante amministratore	Esito minore di 400.
TC_AX_04	Ognuna delle otto rotte riservate agli autenticati, chiamante anonimo	401.

Caso	Condizione	Oracolo
TC_AX_05	Le stesse rotte, chiamante autenticato	Esito minore di 400.
TC_AX_06	Ognuna delle sette rotte pubbliche, chiamante anonimo	Esito minore di 400. Verifica RNF_U_4.
TC_AX_07	Rotta protetta con token non firmato dal server	401: un token manomesso equivale a sessione assente.
TC_AX_08	Rotta pubblica con token non valido	200: la sessione illeggibile non impedisce l'accesso anonimo.
TC_AX_09	Creazione di un feedback con un identificativo utente nel corpo diverso da quello della sessione	Il feedback è attribuito all'utente della sessione. Verifica RNF_F_4.
TC_AX_10	Consegna di un quiz con un identificativo utente nel corpo	Lo svolgimento è attribuito all'utente della sessione. Verifica RNF_F_4.
TC_AX_11	Eliminazione di un feedback altrui da parte di un amministratore	Il servizio è invocato con il privilegio di moderazione.
TC_AX_12	La stessa richiesta da un utente ordinario	Il servizio è invocato senza privilegio di moderazione, e nega l'operazione.

4.7 Infrastruttura

Caso	Condizione	Oracolo
TC_IN_01	Ciascuna classe di errore applicativo	Esposizione dello stato HTTP e il codice previsti ed è istanza di <code>AppError</code> .
TC_IN_02	Errori costruiti senza messaggio	Assumono il messaggio predefinito previsto.
TC_IN_03	<code>ValidationError</code> con e senza dettagli	I dettagli sono conservati quando forniti, assenti altrimenti.
TC_IN_04	Nome del file con risalita <code>../</code>	<code>ValidationError</code> . Verifica RNF_F_7.
TC_IN_05	Nome del file con risalita in notazione Windows	<code>ValidationError</code> .
TC_IN_06	Percorso assoluto	<code>ValidationError</code> .
TC_IN_07	Nome contenente un separatore di percorso	<code>ValidationError</code> .

Caso	Condizione	Oracolo
TC_IN_08	Nome che inizia con un punto	ValidationError.
TC_IN_09	Nome semplice di un file inesistente	Esito negativo senza eccezione: l'eliminazione è idempotente.
TC_IN_10	Nome semplice di un file esistente	Il file è rimosso.
TC_IN_11	Tentativo di risalita verso un file esistente fuori dalla cartella consentita	ValidationError e il file non viene toccato. Verifica RNF_F_7.
TC_IN_12	Costruzione dell'applicazione senza dipendenze esplicite	L'applicazione risponde e tutte le rotte previste risultano montate.
TC_IN_13	Richiesta a una rotta inesistente	404 con il codice d'errore previsto.
TC_IN_14	Intestazioni CORS	Dichiarano l'origine configurata e ammettono le credenziali.

4.8 Casi di test di sistema

I casi che seguono sono eseguiti manualmente su un'istanza completa, con database creato dagli script del progetto. Coprono ciò che la verifica automatica non raggiunge: le interrogazioni SQL, i vincoli di integrità e i trigger.

Caso	Procedura	Oracolo
TC_SY_01	Creazione dello schema ed esecuzione dei dati di esempio	Tutte le tabelle sono popolate; la valutazione media dei tutorial è calcolata dai trigger.
TC_SY_02	Accesso con le credenziali di esempio	Risposta priva di credenziali; cookie con attributo HttpOnly.
TC_SY_03	Consegna di un quiz con risposte corrette, ripetuta su tre tutorial	I badge previsti sono assegnati alle soglie corrette; il contatore dei quiz superati corrisponde.
TC_SY_04	Consegna con risposte inviate in ordine invertito	Esito positivo: verifica dell'associazione per identificativo su dati reali.
TC_SY_05	Pubblicazione di un tutorial con contenuto contenente costrutti eseguibili	Il contenuto memorizzato ne è privo.
TC_SY_06	Inserimento e modifica di un feedback	La valutazione media del tutorial cambia di conseguenza.

Caso	Procedura	Oracolo
TC_SY_07	Eliminazione di un tutorial con quiz e feedback	Quiz, domande, risposte e feedback associati non esistono più.
TC_SY_08	Richiesta di eliminazione di un tutorial da un utente non amministratore	403; il tutorial resta nel catalogo.
TC_SY_09	Tentativo di eliminazione di un file tramite risalita di percorso	400; il file bersaglio esiste ancora.

Esecuzione e risultati

5.1 Esito complessivo

Grandezza	Valore
Suite eseguite	13
Casi di test eseguiti	232
Casi superati	232
Casi falliti	0
Tempo di esecuzione	inferiore a 10 secondi

Tabella 5.1. Esito dell'esecuzione della suite automatica.

Il numero di asserzioni eseguite non coincide con quello dei casi specificati nel capitolo 4 per due ragioni. Alcuni casi sono parametrici: un solo caso specificato, come TC_AX_01, corrisponde a un'asserzione ripetuta su ciascuna delle rotte riservate. Le nove prove di sistema, viceversa, sono manuali e non compaiono fra le asserzioni automatiche. La corrispondenza fra le due numerazioni è riportata nella tabella seguente.

Area	Casi specificati	Asserzioni eseguite
Autenticazione	14	29
Gestione account	10	13
Gestione tutorial	21	28
Gestione quiz	30	29
Gestione feedback	8	17
Gestione obiettivi	18	19
Serializzazione e validazione	—	25
Controllo degli accessi	12	50
Infrastruttura	14	22
Prove di sistema (manuali)	9	—
Totale	136	232

Tabella 5.2. Casi di test specificati e asserzioni effettivamente eseguite.

L'area «Gestione quiz» è l'unica in cui le asserzioni sono meno dei casi specificati: tre casi relativi al livello HTTP sono contati nell'area «Serializzazione e validazione», dove risiede la suite che li contiene. La ripartizione delle asserzioni segue l'organizzazione dei file di test, quella dei casi segue l'organizzazione funzionale del documento.

5.2 Difetti individuati e risolti

I difetti elencati sono stati individuati durante la realizzazione del sistema, in tre modi distinti: dall'analisi statica e dal controllo dei tipi, dalla scrittura dei casi di test, e dalle prove di sistema. Tutti sono chiusi. Sono riportati perché rendono conto di che cosa la verifica ha effettivamente trovato, e perché la loro distribuzione dice qualcosa su quale tecnica ha reso di più.

5.2.1 Difetti di sicurezza

Id	Difetto	Risoluzione e caso di test
DF_01	Le password erano confrontate in chiaro e conservate senza hashing.	Hashing bcrypt in registrazione e confronto in accesso. TC_AU_04.
DF_02	La risposta all'accesso conteneva la password, che veniva conservata nel browser.	Introdotta il livello DTO. TC_AU_11.

Id	Difetto	Risoluzione e caso di test
DF_03	Nessuna rotta verificava identità o ruolo: qualunque chiamante poteva eliminare contenuti e leggere l'elenco degli utenti.	Middleware di autenticazione e autorizzazione. TC_AX_01–TC_AX_06.
DF_04	L'autore di feedback e svolgimenti era preso dal corpo della richiesta.	L'identità è ricavata dalla sessione. TC_AX_09, TC_AX_10.
DF_05	Il contenuto dei tutorial era memorizzato senza sanificazione e reso come HTML.	Sanificazione in ingresso. TC_CT_07, TC_CT_08.
DF_06	L'eliminazione di un'immagine accettava un percorso arbitrario, consentendo di uscire dalla cartella consentita.	Solo nomi semplici, risolti e verificati. TC_IN_04–TC_IN_11.
DF_07	Le risposte corrette dei quiz erano inviate al client, che calcolava l'esito.	Correzione lato server e rimozione del campo dalla rappresentazione. TC_QZ_29.

5.2.2 Difetti funzionali

Id	Difetto	Risoluzione e caso di test
DF_08	Le risposte dell'utente erano associate alle domande per posizione: un ordine di presentazione diverso produceva una correzione errata in silenzio.	Associazione per identificativo. TC_QZ_18.
DF_09	Il contatore dei quiz superati veniva incrementato a ogni superamento, anche ripetendo un quiz già superato: i badge venivano assegnati per traguardi mai raggiunti.	Il valore è ricalcolato dagli svolgimenti registrati. TC_QZ_21, TC_QZ_23.
DF_10	La soglia di superamento era $> 70\%$ nel client e $\geq 70\%$ nel server: un punteggio esattamente pari alla soglia produceva esiti discordanti.	Soglia unica, definita in un solo punto. TC_QZ_17.

Id	Difetto	Risoluzione e caso di test
DF_11	Il limite di lunghezza del commento era 500 caratteri nell'applicazione e 280 nel database: un commento fra i due valori era accettato e poi rifiutato dal DBMS.	Limite allineato a 500 su entrambi i livelli. TC_FB_06, TC_SY_06.
DF_12	Costruzione di oggetti Risposta con argomenti in ordine errato e riferimenti a colonne inesistenti nel livello di persistenza.	Livello di persistenza riscritto con tipi di riga espliciti. Individuato dal controllo dei tipi; coperto da TC_SY_03.
DF_13	Il livello di persistenza degli obiettivi passava riferimenti a funzione al posto dei valori, e alcune istruzioni di aggiornamento avevano i parametri in ordine invertito.	Corretti i riferimenti e l'ordine dei parametri. Individuato in revisione del codice; coperto da TC_SY_03.
DF_14	L'eliminazione di un quiz caricava tutte le domande del database e le filtrava in memoria, pur essendo la cascata già garantita dai vincoli di integrità.	Rimossa la cascata applicativa. TC_QZ_13, TC_SY_07.

5.2.3 Difetti individuati dalle prove di sistema

Id	Difetto	Risoluzione e caso di test
DF_15	Durante la correzione di un quiz l'aggiornamento del contatore dei quiz superati usava il pool di connessioni invece della connessione della transazione in corso: la richiesta attendeva i lock che essa stessa deteneva, e terminava con un errore di attesa scaduta.	La connessione transazionale è propagata a tutti i DAO coinvolti. Individuato da TC_SY_03; coperto da TC_OB_05 e da un'asserzione dedicata sulla propagazione.

Che cosa dice la distribuzione dei difetti. Sette difetti su quindici riguardano la sicurezza e nessuno di essi sarebbe emerso da test funzionali: erano tutti casi in cui il sistema faceva correttamente ciò che gli veniva chiesto, ma da chiunque lo chiedesse. Sono stati trovati formulando i requisiti non funzionali in modo verificabile e scrivendo i casi di test corrispondenti.

DF_15 è l'unico difetto individuato esclusivamente dalle prove di sistema, e riguarda proprio l'area che la verifica automatica non copre: il comportamento transazionale reale del DBMS. È la conferma sperimentale del limite dichiarato in sezione 6.2.

5.3 Copertura del codice

5.3.1 Perimetro di misurazione

La copertura è misurata sul codice che contiene decisioni: servizi, rotte, middleware, errori e serializzazione. Le entità sono escluse dal perimetro: sono contenitori di dati con soli metodi di accesso, esercitati indirettamente da tutte le suite, e includerle gonfierebbe la metrica senza aggiungere garanzie.

5.3.2 Risultati

Modulo	Istr.	Diram.	Funz.	Righe
services/AutenticazioneService	100,0	100,0	100,0	100,0
services/AccountService	97,2	100,0	100,0	97,2
services/TutorialService	100,0	85,7	100,0	100,0
services/QuizService	97,8	88,9	100,0	97,8
services/FeedbackService	100,0	94,4	100,0	100,0
services/ObiettivoService	100,0	91,7	100,0	100,0
routes/auth	100,0	100,0	100,0	100,0
routes/accounts	100,0	100,0	100,0	100,0
routes/tutorials	100,0	87,5	100,0	100,0
routes/quiz	92,3	100,0	83,3	92,3
routes/feedback	100,0	100,0	100,0	100,0
routes/obiettivi	91,3	100,0	80,0	91,3
middleware/auth	84,9	62,5	88,9	84,0
middleware/errorHandler	93,8	66,7	100,0	92,9
middleware/validate	100,0	85,7	100,0	100,0
middleware/asyncHandler	100,0	100,0	100,0	100,0
middleware/upload	62,2	60,0	33,3	63,6
errors/AppError	100,0	100,0	100,0	100,0
dto/index	100,0	50,0	100,0	100,0

Modulo	Istr.	Diram.	Funz.	Righe
Totale	94,9	86,9	93,1	95,0

In valore assoluto: 615 istruzioni coperte su 648, 146 diramazioni su 168, 122 funzioni su 131, 605 righe su 637. Le soglie configurate — 85% di istruzioni, 80% di diramazioni, 85% di funzioni e righe — sono superate, e la loro violazione farebbe fallire la suite.

5.3.3 Analisi delle parti scoperte

Modulo	Che cosa resta scoperto e perché
middleware/upload	È il modulo con la copertura più bassa (62,2%). La parte scoperta è la configurazione di multer e il ridimensionamento delle immagini: codice di inizializzazione e chiamate a librerie esterne, esercitati dalle prove di sistema TC_SY_05. La logica applicativa del modulo — generazione del nome, validazione del percorso — è invece interamente coperta, ed è la parte che ha rilevanza per la sicurezza.
middleware/auth	Restano scoperti alcuni rami difensivi nella decodifica del token: casi in cui il payload è formalmente valido ma privo dei campi attesi. Sono raggiungibili solo con un token firmato dal server e malformato, condizione che non può verificarsi se non manomettendo la chiave.
middleware/errorHandler	Il ramo scoperto è la registrazione dell'errore nei log, disattivata in ambiente di test per non inquinare l'output.
dto/index	La diramazione scoperta è la conversione di una data assente. Riguarda soltanto feedback costruiti in memoria e non ancora persistiti.
routes/quiz, routes/obiettivi	Restano scoperte le rotte di aggiornamento, il cui comportamento è identico a quello delle rotte di creazione già coperte e delega interamente al servizio, a sua volta coperto.
services/TutorialService	Le diramazioni scoperte sono i rami di messaggio d'errore alternativi di uno stesso controllo di validazione, distinguibili solo dal testo prodotto.

Conclusioni

6.1 Valutazione complessiva

I criteri di uscita definiti in capitolo 2 sono soddisfatti: tutti i casi di test sono superati, la copertura supera le soglie configurate e non restano difetti aperti. Il sistema può essere considerato verificato rispetto ai requisiti del RAD, entro i limiti dichiarati nella sezione seguente.

Sotto il profilo del metodo, la verifica ha prodotto due risultati che vale la pena isolare.

Il primo riguarda i requisiti non funzionali. Averli formulati nel RAD con un criterio di accettazione osservabile — invece che come affermazioni generiche sulla qualità — li ha resi traducibili in asserzioni. Sette difetti di sicurezza su quindici sono stati individuati proprio così: erano casi in cui il sistema faceva correttamente ciò che gli veniva chiesto, ma da chiunque lo chiedesse, e nessun test funzionale li avrebbe rivelati.

Il secondo riguarda la progettazione. La possibilità di verificare ogni servizio in isolamento non è una proprietà della suite ma del sistema: deriva dalla decisione, presa nel SDD, di passare le dipendenze dai costruttori. Senza di essa la stessa verifica richiederebbe di aggirare l’incapsulamento per sostituire un collaboratore. La difficoltà a scrivere un test si è rivelata, in questo progetto, un indicatore attendibile di un problema di progettazione, e in più di un caso ha portato a rivedere l’interfaccia di una classe prima ancora di verificarla.

6.2 Limiti della verifica

Limite	Rischio residuo	Mitigazione
Il livello di persistenza è sostituito da doppi: le interrogazioni SQL non sono eseguite dalla verifica automatica.	Un errore in una query — nome di colonna, ordine dei parametri — non viene intercettato prima dell’esecuzione. È accaduto: DF_12 e DF_13 sono difetti di questa natura.	Prove di sistema TC_SY_01–TC_SY_09 su un database reale, da eseguire prima di ogni rilascio. Il livello è sottile e privo di logica condizionale, il che riduce la superficie esposta.

Limite	Rischio residuo	Mitigazione
I trigger che mantengono la valutazione media vivono nel database.	Una modifica ai trigger non è rilevata da alcun test automatico.	TC_SY_06 verifica il ricalcolo su dati reali.
Non esistono test automatici sull'interfaccia utente.	Un difetto nella composizione dei componenti o nella gestione dello stato non viene rilevato.	Controllo dei tipi e analisi statica sull'intero client; verifica manuale dei percorsi principali. Il client non contiene regole di dominio: la logica che conta è verificata sul server.
Le prove di sistema sono manuali.	Possono essere omesse sotto pressione, ed è il momento in cui servirebbero di più.	Sono elencate come casi di test con procedura e oracolo espliciti, non come lista di controllo informale.
La verifica non comprende prove di carico o di sicurezza offensive.	Il comportamento sotto carico e la resistenza ad attacchi non elementari non sono noti.	Fuori dagli obiettivi del progetto; le contromisure adottate sono documentate nel SDD e verificate a livello funzionale.

6.3 Interventi proposti

Gli interventi che seguono non sono difetti ma direzioni di miglioramento della verifica, ordinate per rapporto fra beneficio e costo.

1. **Test di integrazione su un database effimero.** Eseguire le prove di sistema automaticamente su un'istanza MySQL creata e distrutta dalla catena di integrazione chiuderebbe il limite principale. È il singolo intervento con il beneficio maggiore.
2. **Verifica automatica dei percorsi principali del client.** Una manciata di prove end-to-end su accesso, svolgimento di un quiz e inserimento di un feedback coprirebbe le regressioni più probabili nell'interfaccia.
3. **Casi di test sui trigger.** Verificabili con asserzioni SQL dirette, una volta disponibile un database nella catena di integrazione.
4. **Analisi di mutazione.** La copertura dice quali righe sono eseguite, non se le asserzioni sono in grado di rilevare un cambiamento di comportamento. Un'analisi di mutazione sui servizi darebbe una misura più severa dell'adeguatezza dei casi di test.

Glossario

7.1 Termini del dominio

Termine	Definizione
Utente	Persona registrata alla piattaforma. Consulta i tutorial, svolge i quiz, lascia feedback e consegue badge. Nel codice: classe <code>Utente</code> .
Amministratore	Utente con privilegi di gestione: crea e modifica tutorial, quiz e obiettivi, modera i feedback e amministra gli account. È un ruolo dell'entità <code>Utente</code> , non un'entità distinta.
Ruolo	Attributo dell'utente che ne determina i permessi. Assume i valori <code>utente</code> e <code>admin</code> . Nel codice: enumerazione <code>Ruolo</code> .
Tutorial	Unità didattica composta da titolo, immagine di copertina, contenuto testuale e categoria. È l'oggetto centrale del catalogo.
Categoria	Classificazione tematica di un tutorial. L'insieme è chiuso: Internet, Social Media, Tecnologia, Sicurezza.
Quiz	Prova di verifica associata a un solo tutorial, composta da domande a scelta multipla. La correzione è responsabilità esclusiva del server.
Domanda	Quesito a scelta multipla appartenente a un quiz, con esattamente una risposta corretta fra le opzioni proposte.
Risposta	Singola opzione di una domanda. L'indicazione di correttezza non lascia mai il server prima della consegna del quiz.
Svolgimento	Registrazione del tentativo di un utente su un quiz: esito, numero di risposte esatte e data. Un utente conserva un solo svolgimento per quiz.
Soglia di superamento	Frazione di risposte corrette necessaria a superare un quiz, pari al 70%.
Feedback	Valutazione da 1 a 5 con commento, lasciata da un utente su un tutorial. Un utente può lasciarne al più uno per tutorial.
Valutazione media	Media dei feedback ricevuti da un tutorial, mantenuta dal database e trattata come sola lettura dal codice applicativo.

Termine	Definizione
Obiettivo	Traguardo raggiungibile superando un numero prestabilito di quiz. Al raggiungimento viene assegnato il badge associato.
Badge	Riconoscimento visivo assegnato a un utente al conseguimento di un obiettivo.
Conseguimento	Associazione fra un utente e un obiettivo raggiunto, con la data di assegnazione.
Catalogo	Insieme dei tutorial pubblicati, consultabile anche senza autenticazione.
Sessione	Periodo in cui un utente è riconosciuto dal sistema, materializzato da un token firmato conservato in un cookie <code>httpOnly</code> .

7.2 Termini tecnici

Termine	Definizione
DAO	<i>Data Access Object</i> : oggetto che incapsula l'accesso a una tabella o a un aggregato del database, isolando il resto del sistema dal linguaggio SQL.
DTO	<i>Data Transfer Object</i> : struttura dati priva di comportamento usata per trasferire informazioni oltre il confine del sistema. In Tech4All è l'unico punto in cui le entità vengono serializzate verso il client.
Servizio	Oggetto che realizza le regole di dominio di un sottosistema, coordinando uno o più DAO. Non conosce il protocollo HTTP.
Middleware	Funzione interposta nella catena di elaborazione di una richiesta HTTP, che può interromperla o arricchirla.
Aggregato	Insieme di entità con un unico punto d'accesso e un ciclo di vita comune. In Tech4All quiz, domande e risposte formano un solo aggregato.
Hash	Trasformazione irreversibile di un valore. Le password sono conservate solo come hash, mai in chiaro.
Sanificazione	Rimozione dai contenuti HTML dei costrutti eseguibili, applicata prima della persistenza.
Transazione	Sequenza di operazioni sul database che viene applicata per intero o non applicata affatto.
Copertura del codice	Frazione del codice sorgente eseguita durante i test, misurata su istruzioni, dichiarazioni, funzioni e righe.

7.3 Acronimi

Sigla	Significato
API	<i>Application Programming Interface</i>
CI	<i>Continuous Integration</i>
CORS	<i>Cross-Origin Resource Sharing</i>
CRUD	<i>Create, Read, Update, Delete</i>
DBMS	<i>Database Management System</i>
DTO	<i>Data Transfer Object</i>
DAO	<i>Data Access Object</i>
FURPS+	<i>Functionality, Usability, Reliability, Performance, Supportability e vincoli aggiuntivi</i>
HTTP	<i>HyperText Transfer Protocol</i>
JSON	<i>JavaScript Object Notation</i>
JWT	<i>JSON Web Token</i>
ODD	<i>Object Design Document</i>
RAD	<i>Requirements Analysis Document</i>
REST	<i>Representational State Transfer</i>
RF	Requisito Funzionale
RNF	Requisito Non Funzionale
SDD	<i>System Design Document</i>
SQL	<i>Structured Query Language</i>
UC	<i>Use Case</i> , caso d'uso
UML	<i>Unified Modeling Language</i>
XSS	<i>Cross-Site Scripting</i>

Matrice di tracciabilità

Questa appendice chiude la catena di tracciabilità del progetto. Il RAD lega requisiti, casi d'uso e scenari; il SDD lega i requisiti non funzionali agli obiettivi di progettazione e ai meccanismi che li realizzano; qui ogni requisito è legato ai casi di test che lo verificano.

Un requisito privo di casi di test associati sarebbe un requisito non verificato: le tabelle che seguono servono anche a rendere immediatamente visibile un'eventuale lacuna.

A.1 Requisiti funzionali

Requisito	Classe o rotta verificata	Casi di test
RF_AU_1	AutenticazioneService.registra	TC_AU_01–TC_AU_04, TC_AU_12
RF_AU_2	AutenticazioneService.login	TC_AU_05–TC_AU_07, TC_AU_10
RF_AU_3	POST /auth/logout	TC_AU_13
RF_AU_4	AccountService.getUtente	TC_AU_11, TC_AX_04
RF_AU_5	AutenticazioneService.emailEsiste	TC_AU_08, TC_AU_09
RF_AU_6	AccountService.aggiornaProfilo	TC_AC_01–TC_AC_04
RF_AU_7	AccountService.aggiornaProfilo	TC_AC_05–TC_AC_08
RF_AU_8	AccountService.eliminaUtente	TC_AC_09, TC_AC_10
RF_AU_9	GET /accounts	TC_AX_01–TC_AX_03
RF_AU_10	DELETE /accounts/:id	TC_AX_01–TC_AX_03
RF_CT_1	TutorialService.getTutorials	TC_CT_09, TC_AX_06
RF_CT_2	TutorialService.getTutorials	TC_CT_10–TC_CT_12
RF_CT_3	TutorialService.cercaTutorial	TC_CT_13, TC_CT_14
RF_CT_4	TutorialService.getTutorial	TC_AX_06
RF_CT_5	GET /tutorials/categorie	TC_AX_06

Requisito	Classe o rotta verificata	Casi di test
RF_CT_6	TutorialService.creaTutorial	TC_CT_01–TC_CT_08, TC_CT_19
RF_CT_7	TutorialService.aggiornaTutorial	TC_CT_15, TC_CT_16, TC_CT_20, TC_CT_21
RF_CT_8	TutorialService.eliminaTutorial	TC_CT_17, TC_CT_18, TC_SY_07
RF_CT_9	POST /tutorials/immagini	TC_IN_04–TC_IN_11
RF_CT_10	eliminaImmagineContenuto	TC_IN_04–TC_IN_11
RF_QZ_1	toQuizDTO	TC_QZ_29, TC_AX_06
RF_QZ_2	QuizService.eseguiQuiz	TC_QZ_15–TC_QZ_28, TC_QZ_30
RF_QZ_3	QuizService.creaQuiz	TC_QZ_01–TC_QZ_10
RF_QZ_4	QuizService.aggiornaQuiz	TC_QZ_11, TC_QZ_12
RF_QZ_5	QuizService.eliminaQuiz	TC_QZ_13, TC_QZ_14
RF_FB_1	FeedbackService.getFeedbackTutorial	TC_AX_06
RF_FB_2	FeedbackService.getFeedbackUtente	TC_AX_04
RF_FB_3	FeedbackService.creaFeedback	TC_FB_01–TC_FB_08
RF_FB_4	FeedbackService.aggiornaFeedback	TC_FB_01, TC_FB_08
RF_FB_5	FeedbackService.eliminaFeedback	TC_AX_12
RF_FB_6	FeedbackService.eliminaFeedback	TC_AX_11
RF_OB_1	ObiettivoService.getObiettivi	TC_AX_06
RF_OB_2	ObiettivoService.getBadgeUtente	TC_OB_06, TC_OB_07
RF_OB_3	ObiettivoService.valutaConseguimenti	TC_OB_01–TC_OB_05, TC_QZ_25
RF_OB_4	ObiettivoService.creaObiettivo	TC_OB_08–TC_OB_14
RF_OB_5	ObiettivoService.aggiornaObiettivo	TC_OB_15, TC_OB_16
RF_OB_6	ObiettivoService.eliminaObiettivo	TC_OB_17, TC_OB_18

A.2 Requisiti non funzionali

Requisito	Criterio di accettazione verificato	Casi di test
RNF_F_1	La password non compare in alcuna risposta ed è memorizzata come hash.	TC_AU_04, TC_AU_07, TC_AU_11
RNF_F_2	Le richieste di modifica prive di sessione ricevono 401.	TC_AX_01, TC_AX_04, TC_AX_07
RNF_F_3	Le stesse richieste, da utente non amministratore, ricevono 403.	TC_AX_02, TC_SY_08
RNF_F_4	Un identificativo utente nel corpo della richiesta viene ignorato.	TC_AX_09, TC_AX_10
RNF_F_5	Il contenuto memorizzato è privo di costrutti eseguibili.	TC_CT_07, TC_CT_08, TC_SY_05
RNF_F_6	La rappresentazione del quiz non distingue la risposta corretta.	TC_QZ_29
RNF_F_7	Un nome di file con separatori o risalite è rifiutato.	TC_IN_04–TC_IN_11, TC_SY_09
RNF_U_2	Le risposte di validazione elencano i campi non conformi.	TC_AU_02, TC_AU_03
RNF_U_4	Le rotte di consultazione rispondono a un chiamante anonimo.	TC_AX_06, TC_AX_08
RNF_A_1	Le operazioni composite sono atomiche.	TC_OB_05, TC_SY_03
RNF_A_2	La risposta 500 non contiene dettagli interni.	TC_AU_14
RNF_A_3	La copertura non scende sotto le soglie configurate.	sezione 5.3
RNF_A_4	Ripetere un quiz superato non altera il conteggio.	TC_QZ_21, TC_QZ_23, TC_QZ_24
RNF_P_1	L'aggregato quiz è letto con una sola interrogazione.	TC_SY_03
RNF_P_2	Filtro e ricerca sono eseguiti dalla base di dati.	TC_CT_11, TC_CT_13
RNF_S_2	I vincoli di dominio hanno un'unica definizione.	TC_QZ_17 (soglia), TC_FB_06 (lunghezza)
RNF_S_3	Analisi statica, tipi, test e compilazione a ogni integrazione.	capitolo 2

Requisiti non coperti da casi di test automatici. RNF_U_1 (linguaggio non tecnico) e RNF_U_3 (conferma delle operazioni irreversibili) riguardano l'interfaccia e sono verificati per ispezione; RNF_S_1 (uniformità dei sottosistemi) è una proprietà strutturale verificabile per ispezione del codice. Sono gli unici tre requisiti privi di un caso di test eseguibile, e la ragione è che nessuno dei tre è esprimibile come asserzione su un comportamento osservabile.

Riferimenti bibliografici

- [1] IEEE. *IEEE Standard for Software and System Test Documentation*. Rapp. tecn. IEEE Std 829-2008. IEEE Computer Society, 2008.
- [2] Thomas J. Ostrand e Marc J. Balcer. «The Category-Partition Method for Specifying and Generating Functional Tests». In: *Communications of the ACM* 31.6 (1988), pp. 676–686. doi: 10.1145/62959.62964.
- [3] OWASP Foundation. *OWASP Top 10: 2021*. <https://owasp.org/Top10/>. 2021. (Visitato il giorno 27/08/2026).